Introduction

The purpose of this document is to evaluate potential security weaknesses and implement security controls within the mobile app's infrastructure.

Scope of Work

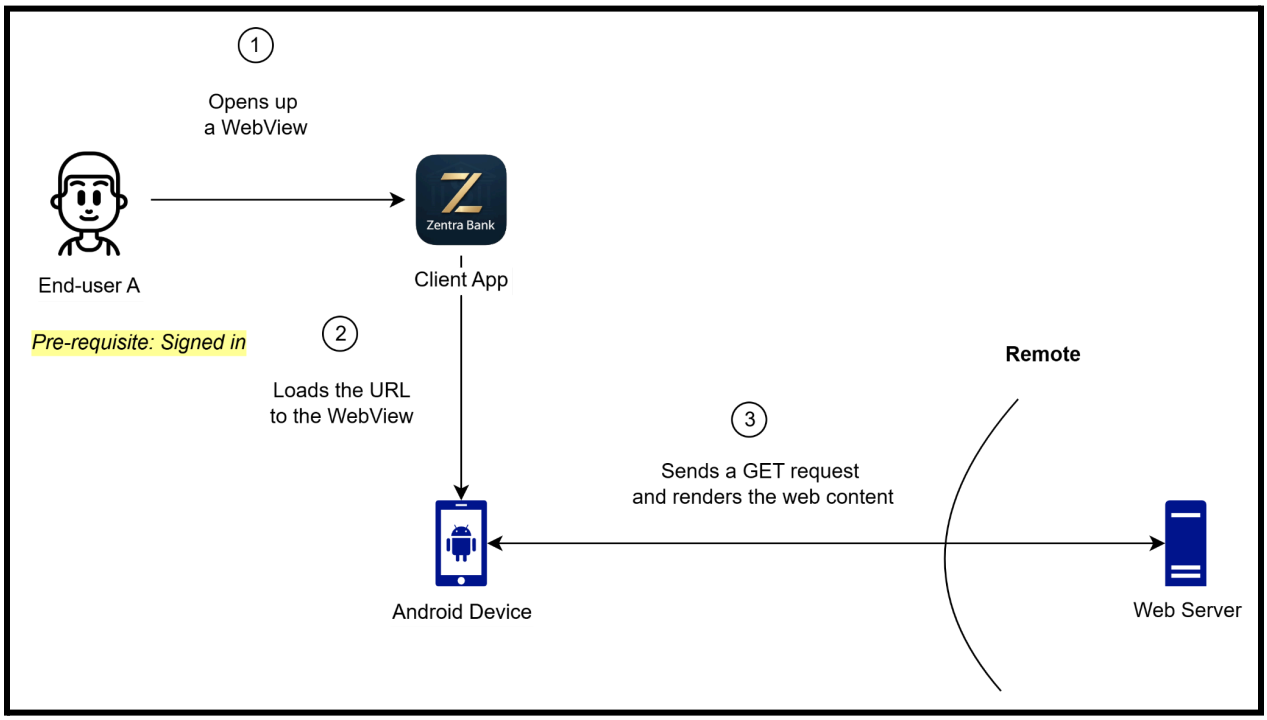
This exercise focuses on 1 user story within the Zentra Bank mobile app:

1. As a user, I want to **view web content through a web view** so that I don't have to switch to an external browser.

Out of Scope

This exercise strictly focuses on the mobile application and its functionalities. Any components outside the mobile app, which includes but not limited to REST APIs, server infrastructure, remote database, and external services, are not within the scope.

User story 7



The data flow for this user story is as follows:

"As a user, I want to view web content through a web view so that I don't have to switch to an external browser."

1. The **End-user** opens up a WebView
2. The **Client App (CA)** loads the URL to the WebView (i.e. csa.gov.sg)
3. The **Android Operating System (AOS)** WebView sends a GET request and renders the web content in the WebView

▼ Request Headers

:authority	www.csa.gov.sg
:method	GET
:path	/
:scheme	https
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding	gzip, deflate, br, zstd
Accept-Language	en-US,en;q=0.9
Cache-Control	max-age=0
Cookie	_sp_ses.3ab5=*; _sp_id.3ab5=b537e8be-ea4f-4e40-94e5-241e2622a072.1759833017.2.1759985940.1759833020.2a01a1b3-5465-48cc-853f-ea45483df6ca.426e9b31-b641-4569-8ad9-967082eba59b...0; _ga_5KSX69ZFL1=GS2.1.s1759985941$o2$g0$t1759985941$j60$l0$h0; _clck=8844f4%5E2%5Eg00%5E0%5E2106; _ga=GA1.3.558245804.1759833019; _gid=GA1.3.76484450.1759985942; _gat_gtag_UA_216510461_1=1; _clsk=1qzodgp%5E1759985943417%5E1%5E0%5Ev.clarity.ms%2Fcollect
If-Modified-Since	Wed, 08 Oct 2025 10:14:26 GMT
If-None-Match	W/"3219ae5d98228d3e4d5540e917f15c9a"
Priority	u=0, i
Sec-Ch-Ua	"Chromium";v="140", "Not=A?Brand";v="24", "Android WebView";v="140"
Sec-Ch-Ua-Mobile	?1
Sec-Ch-Ua-Platform	"Android"
Sec-Fetch-Dest	document
Sec-Fetch-Mode	navigate
Sec-Fetch-Site	same-origin
Sec-Fetch-User	?1
Upgrade-Insecure-Requests	1
User-Agent	Mozilla/5.0 (Linux; Android 10; Android SDK built for x86 Build/QSR1.211112.011; wv) AppleWebKit/537.36 (KHTML, like Gecko) Version/4.0 Chrome/140.0.7339.207 Mobile Safari/537.36
X-Requested-With	com.csec.zentra

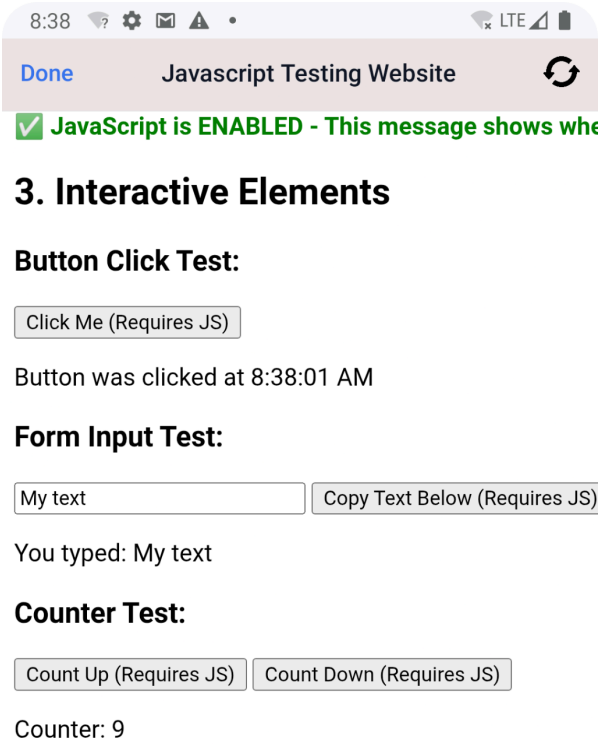
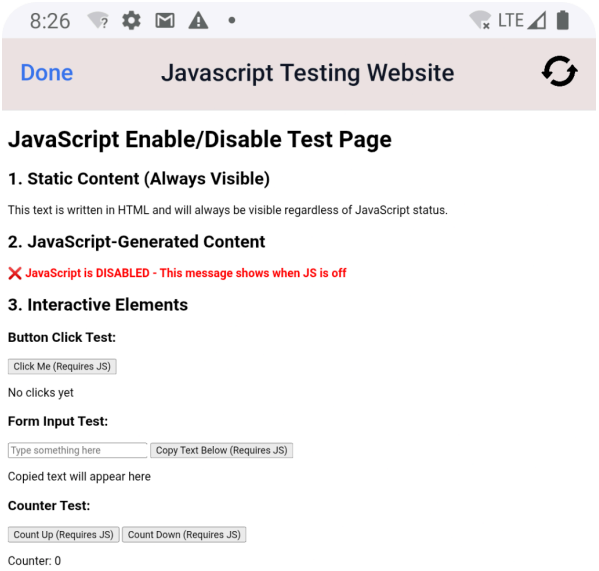
▼ Response Headers

Age	456
Alt-Svc	h3=":443"; ma=86400
Cache-Control	max-age=600
Content-Security-Policy	default-src 'none';base-uri 'self';script-src 'self' 'unsafe-inline' blob: https://api.search.gov.sg https://www.search.gov.sg https://*.wogaa.sg https://www.google-analytics.com https://www.googletagmanager.com https://connect.facebook.net https://graph.facebook.com https://*.licdn.com https://www.youtube.com https://webchat.vica.gov.sg https://webchat.mol-vica.com https://*.clarity.ms https://*.ask.gov.sg ;style-src 'self' 'unsafe-inline' https://assets.wogaa.sg https://www.search.gov.sg https://webchat.vica.gov.sg https://webchat.mol-vica.com ;object-src 'none' ;connect-src 'self' https://isomer-user-content.by.gov.sg https://browser-intake-datadoghq.com https://api.search.gov.sg https://*.wogaa.sg https://api-chat-fe-flag.vica.gov.sg https://chat.vica.gov.sg wss://chat.vica.gov.sg https://api-chat-fe-flag.mol-vica.com https://chat.mol-vica.com wss://chat.mol-vica.com https://www.google-analytics.com https://www.google.com https://analytics.google.com https://stats.g.doubleclick.net https://px.ads.linkedin.com https://*.clarity.ms https://c.bing.com https://ask.gov.sg https://*.ask.gov.sg https://data.gov.sg https://*.data.gov.sg ;font-src 'self' data: https://fonts.gstatic.com https://www.search.gov.sg https://assets.wogaa.sg ;frame-src 'self' https://www.search.gov.sg https://www.google.com https://www.googletagmanager.com https://td.doubleclick.net https://www.onemap.gov.sg https://www.youtube-nocookie.com https://player.vimeo.com https://m.facebook.com https://www.facebook.com https://docs.google.com https://form.gov.sg https://maps.gov.sg ;img-src 'self' https: ;manifest-src 'self' ;media-src 'self' ;worker-src 'self' ;frame-ancestors 'self' ;
Date	Thu, 09 Oct 2025 04:52:15 GMT
Etag	W/"3219ae5d98228d3e4d5540e917f15c9a"
Last-Modified	Wed, 08 Oct 2025 10:14:26 GMT
Referrer-Policy	strict-origin-when-cross-origin
Server	AmazonS3
Strict-Transport-Security	max-age=31536000
Vary	accept-encoding
Vary	Origin
Via	1.1 b93539311f65854b91591e3ebce387d2.cloudfront.net (CloudFront)
X-Amz-Cf-Id	qDGhw744kibVuqJXjLLLYhjWHkXinp37CW9CAh1w_2jQ-e5iEQ_-iw==
X-Amz-Cf-Pop	SIN2-P6
X-Amz-Server-Side-Encryption	AES256
X-Amz-Version-Id	bphrGCsNTVwhWYgx_6sc9wIfe1s3GOvC
X-Cache	Hit from cloudfront
X-Content-Type-Options	nosniff
X-Frame-Options	SAMEORIGIN
X-Xss-Protection	1; mode=block

WebView (FAQ)

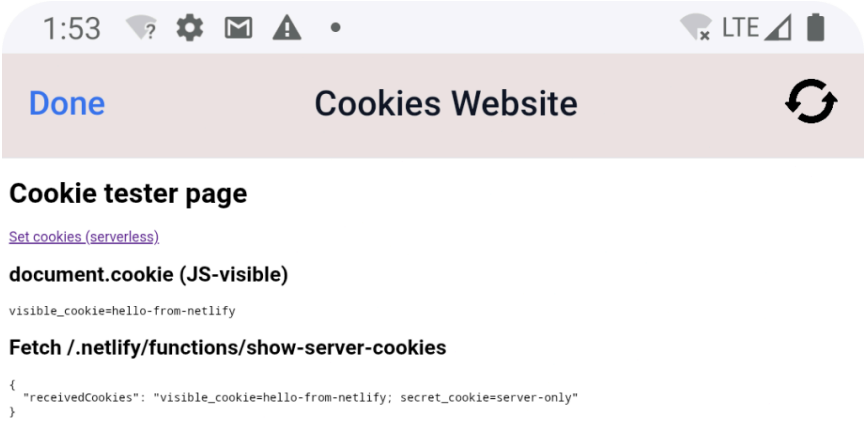
What happens when JavaScript is disabled?

When JavaScript is disabled. Observe that while the html page can still be rendered, JavaScript features like allowing buttons to be clicked, will not work.

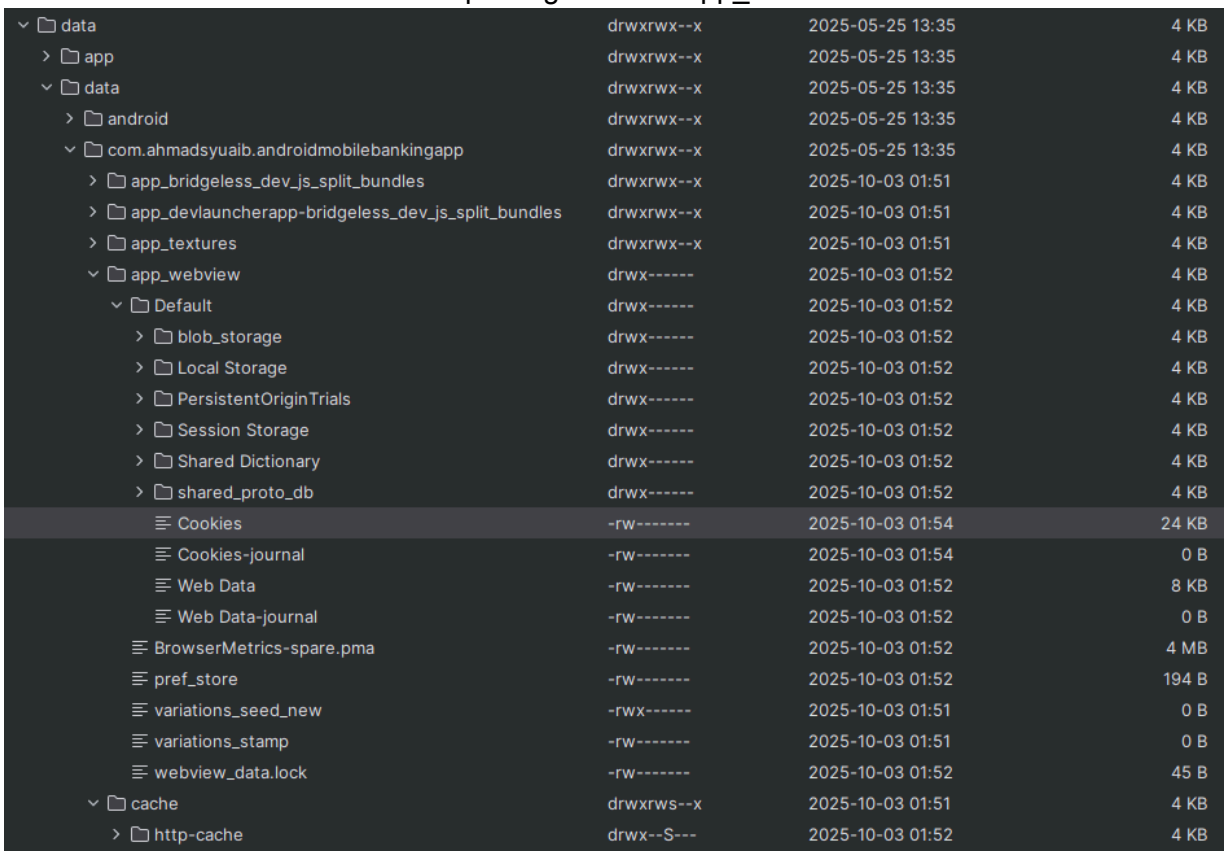
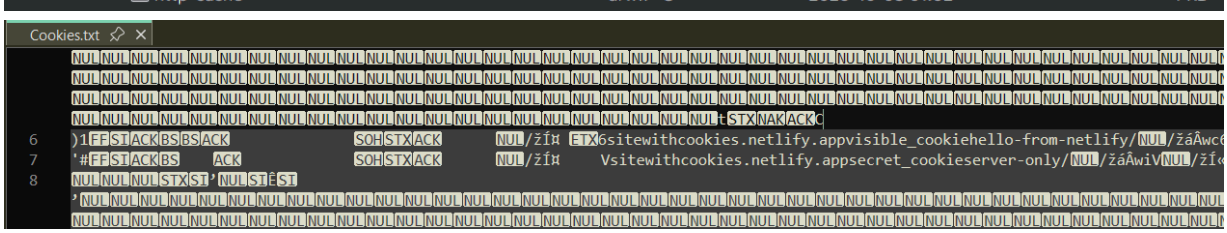
JavaScript enabled.	JavaScript disabled.
	

Does WebView use cookies?

WebView uses cookies, and it's stored within the app's internal storage. Observe that cookies are being stored within the app's internal storage directory.



Cookies file is stored in /data/data/<package-name>/app_webview/Default/cookies



data	drwxrwx--x	2025-05-25 13:35	4 KB
app	drwxrwx--x	2025-05-25 13:35	4 KB
data	drwxrwx--x	2025-05-25 13:35	4 KB
android	drwxrwx--x	2025-05-25 13:35	4 KB
com.ahmadsyuaib.androidmobilebankingapp	drwxrwx--x	2025-05-25 13:35	4 KB
app_bridgeless_dev_js_split_bundles	drwxrwx--x	2025-10-03 01:51	4 KB
app_devlauncherapp-bridgeless_dev_js_split_bundles	drwxrwx--x	2025-10-03 01:51	4 KB
app_textures	drwxrwx--x	2025-10-03 01:51	4 KB
app_webview	drwx------	2025-10-03 01:52	4 KB
Default	drwx------	2025-10-03 01:52	4 KB
blob_storage	drwx------	2025-10-03 01:52	4 KB
Local Storage	drwx------	2025-10-03 01:52	4 KB
PersistentOriginTrials	drwx------	2025-10-03 01:52	4 KB
Session Storage	drwx------	2025-10-03 01:52	4 KB
Shared Dictionary	drwx------	2025-10-03 01:52	4 KB
shared_proto_db	drwx------	2025-10-03 01:52	4 KB
Cookies	-rw-------	2025-10-03 01:54	24 KB
Cookies-journal	-rw-------	2025-10-03 01:54	0 B
Web Data	-rw-------	2025-10-03 01:52	8 KB
Web Data-journal	-rw-------	2025-10-03 01:52	0 B
BrowserMetrics-spare.pma	-rw-------	2025-10-03 01:52	4 MB
pref_store	-rw-------	2025-10-03 01:52	194 B
variations_seed_new	-rwx------	2025-10-03 01:51	0 B
variations_stamp	-rw-------	2025-10-03 01:51	0 B
webview_data.lock	-rw-------	2025-10-03 01:52	45 B
cache	drwxrws--x	2025-10-03 01:51	4 KB
http-cache	drwx--S---	2025-10-03 01:52	4 KB